

MAGNA · SECURITY REVIEW

Magna

Direct Transfer Review.

A security review of Direct Transfer Review.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Magna	Direct Transfer Review	Guardian	October 15 – October 17, 2025	October 23, 2025

§ 00

Contents.

18 pages — overview, confidence ranking, scope, 9 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 9 findings	P. 08
§ 05	Disclaimer	P. 17
§ 06	About Guardian	P. 18

§ 01

Overview.

Guardian reviewed Direct Transfer Review across a single review round. The final report includes 1 Medium, 1 Low, 7 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	magna-eng/protocol-direct-transfer-evm
CLIENT	METHODOLOGY
Magna	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
Direct Transfer Review	3bbb8bee6325
PREPARED BY	
Guardian	
AUDIT WINDOW	
October 15 – October 17, 2025	
FINAL REPORT	
October 23, 2025	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	1	0	0	0	1
Low	1	0	1	0	0
Informational	7	0	4	0	3
All severities	9	0	5	0	4

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Direct Transfer Review in `magna-eng/protocol-direct-transfer-evm`. The scope includes 126 source lines across 4 files.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW
Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
src/IMagnaDirectAirdrop.sol	10	15
src/IMagnaDirectAirdropFactory.sol	6	11
src/MagnaDirectAirdrop.sol	90	151
src/MagnaDirectAirdropFactory.sol	20	30

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
M-01	Native Token Cannot Be Airdropped	DoS	MEDIUM	RESOLVED	p. 8
L-01	Anyone Can Create Airdrops	Validation	LOW	ACKNOWLEDGED	p. 9
I-01	Maximum Number Of Contracts Not Bound	Validation	INFORMATIONAL	RESOLVED	p. 10
I-02	Airdrop Can Be Reverted	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 11
I-03	Incomplete Event Data	Events	INFORMATIONAL	ACKNOWLEDGED	p. 12
I-04	Unused Address Library	Superfluous Code	INFORMATIONAL	RESOLVED	p. 13
I-05	Tokens With Hooks Can Be Flashloaned	Warning	INFORMATIONAL	ACKNOWLEDGED	p. 14
I-06	Empty Recipients Should Revert	Error	INFORMATIONAL	ACKNOWLEDGED	p. 15
I-07	Inaccurate Comments	Best Practices	INFORMATIONAL	RESOLVED	p. 16

MEDIUM **M-01**

RESOLVED

Native Token Cannot Be Airdropped

CATEGORY DoS
LOCATION MagnaDirectAirdrop.sol#L39
REVIEW Main Review

DESCRIPTION

The payable `MagnaDirectAirdrop.disperseNativeToken()` function should allow users to airdrop native tokens by sending them with the call.

The function records the balance of the contract before assets are send, including the `msg.value` which should be distributed`

```
uint256 tokenBalanceBefore = address(this).balance;
```

Then it transfers the tokens to the recipients and finally performs the following check

```
require(address(this).balance - tokenBalanceBefore == 0);
```

The idea of the check is to ensure exactly the desired amount was sent to the recipients, but because `tokenBalanceBefore` includes `msg.value`, the calculation will always underflow. In result, distributing native tokens with the contract is impossible.

RECOMMENDATION

Exclude the `msg.value` from the contract balance when taking the first snapshot.

```
- uint256 tokenBalanceBefore = address(this).balance;
```

```
+ uint256 tokenBalanceBefore = address(this).balance - msg.value;
```

PROOF OF CONCEPT <https://github.com/GuardianOrg/protocol-direct-transfer-evm-team1-1760563346287/blob/nativeTokenDispersal/test/Factory.t.sol>

RESOLUTION

Status: Resolved.

LOW **L-01**

ACKNOWLEDGED

Anyone Can Create Airdrops

CATEGORY Validation
LOCATION MagnaDirectAirdropFactory.sol#L18-25
REVIEW Main Review

DESCRIPTION

`MagnaDirectAirdropFactory.createDirectAirdropContract()` is not permissioned, which allows any user to create contracts for themselves, with `owner` being an address chosen by them. A malicious user can DOS a factory by deploying as much contracts as needed until `directAirdropContracts.length == maximumNumberOfContracts`. Then nobody will be able to deploy more contracts from that factory.

Furthermore, if `maximumNumberOfContracts` is set to a high value, letting anyone create contracts raises the risk of `getDirectAirdropContracts()` reverting because of `00G`.

RECOMMENDATION

Consider having an owner set during deployment of the factory and allow only them to deploy contracts.

PROOF OF CONCEPT https://github.com/GuardianOrg/protocol-direct-transfer-evm-team1-1760563346287/blob/malicious_deploys/test/Factory.t.sol

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01**

RESOLVED

Maximum Number Of Contracts Not Bound

CATEGORY Validation
LOCATION MagnaDirectAirdropFactory.sol#L15
REVIEW Main Review

DESCRIPTION

The constructor of the factory contract accepts `maximumNumberOfContracts_` parameter that's used to validate the number of created instances via this factory. Since there is no validation performed on this parameter, factories with 0 allowed contracts can be deployed. Such factories don't serve any purpose because they cannot deploy even a single contract.

On the other hand, it's also possible to create a factory with `maximumNumberOfContracts_ = type(uint256.max)`. This can cause an `00G` revert for the `getDirectAirdropContracts()` function if the instances are too much and lead to reverts for third-party integrators.

RECOMMENDATION

Consider bounding the `_maximumNumberOfContracts` between 1 and an appropriate maximum value.

PROOF OF CONCEPT https://github.com/GuardianOrg/protocol-direct-transfer-evm-team1-1760563346287/blob/initialize_with_0/test/Factory.t.sol

RESOLUTION

Status: Resolved.

INFORMATIONAL I-02

ACKNOWLEDGED

Airdrop Can Be Reverted

CATEGORY Warning
LOCATION MagnaDirectAirdrop.sol
REVIEW Main Review

DESCRIPTION

After each airdrop dispersal, it's enforced as an invariant that all of the funds received from the sender are spent. This opens up the possibility of DOS-ing the airdrop via malicious receiver for tokens with hooks.

In `disperseNativeToken()` the following is mentioned:

```
// 1. recipients intentionally reverting should be removed from the airdrop
```

However, this case is slightly different because the recipient itself is not reverting, they are just sending 1 wei of the token back to the contract, which will make it seem like they were a legit recipient, while the transaction will later revert because of the following check:

```
require(token.balanceOf(address(this)) - tokenBalanceBefore == 0);
```

Depending on how such failures are handled - for example, if there is an automated process which checks for recipients that caused the revert and submits the dispersal again - this behavior may cause unexpected results. The described scenario cannot happen with native tokens because the contract reverts

RECOMMENDATION

Keep that in mind when you explore reverting airdrops.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-03

ACKNOWLEDGED

Incomplete Event Data

CATEGORY	Events
LOCATION	MagnaDirectAirdrop.sol
REVIEW	Main Review

DESCRIPTION

Whenever a dispersal is performed, the `AirdropCompleted(idempotencyKey, msgSender)` event is emitted. Only `idempotencyKey` and `msgSender` and no `token` are being emitted, which may not be enough for offchain listeners to parse the dispersal. In addition, airdrops can be performed by anyone and any tokens can be supplied, so it's preferable to include the token address as well.

RECOMMENDATION

Include the token address in the event emission.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-04**

RESOLVED

Unused Address Library

CATEGORY	Superfluous Code
LOCATION	MagnaDirectAirdrop.sol#L8
REVIEW	Main Review

DESCRIPTION

The `Address` library from OpenZeppelin is imported in the `MagnaDirectAirdrop` contract, but its functionality is never used.

RECOMMENDATION

Remove the library from the contract.

RESOLUTION

Status: Resolved.

INFORMATIONAL I-05

ACKNOWLEDGED

Tokens With Hooks Can Be Flashloaned

CATEGORY Warning
LOCATION MagnaDirectAirdrop.sol
REVIEW Main Review

DESCRIPTION

Any tokens with hooks staying in the contract can be flashloaned in the following way:

- call `disperseERC20Token()` with yourself as the recipient, `total = 0` and `value = token.balanceOf(contract)`.
- Since total is 0, you don't pay anything, but receive the whole balance
- Perform some actions and return the funds

RECOMMENDATION

Document this behavior.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-06**

ACKNOWLEDGED

Empty Recipients Should Revert

CATEGORY	Error
LOCATION	MagnaDirectAirdrop.sol
REVIEW	Main Review

DESCRIPTION

Each disperse function computes `recipientsLength = recipients.length - 1` before validating `recipients.length == values.length`. When `recipients.length == 0`, this underflows and reverts with a Panic error, yielding a non-descriptive failure and bypassing the intended input validation path.

RECOMMENDATION

Add an explicit `require(recipients.length > 0, 'Empty')` (or a custom error) before subtracting 1, and then keep the existing length-equality check. This avoids unexpected Panic errors and improves diagnosability.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-07**

RESOLVED

Inaccurate Comments

CATEGORY Best Practices
LOCATION MagnaDirectAidrop.sol
REVIEW Main Review

DESCRIPTION

The following comments are not accurate:

1. [MagnaDirectAidrop.sol#L101](https://github.com/GuardianOrg/protocol-direct-transfer-evm-team1-1760563346287/blob/3bbb8bee6325df471801b2a97bc55c5d6fbf22b5/src/MagnaDirectAidrop.sol#L101) - it's in the `safeDisperseERC20Token()` and says `safeTransfer` is not used which is not true. The comment was probably copied from `disperseERC20Token()` and forgotten.

RECOMMENDATION

1. Delete the comment

RESOLUTION

Status: Resolved.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.